

T.P. de RESEAUX n° R3.Cyber.04

Sécurisation des accès réseau, Traçabilité et Haute
Disponibilité (AAA & RADIUS)



UNIVERSITÉ
CÔTE D'AZUR

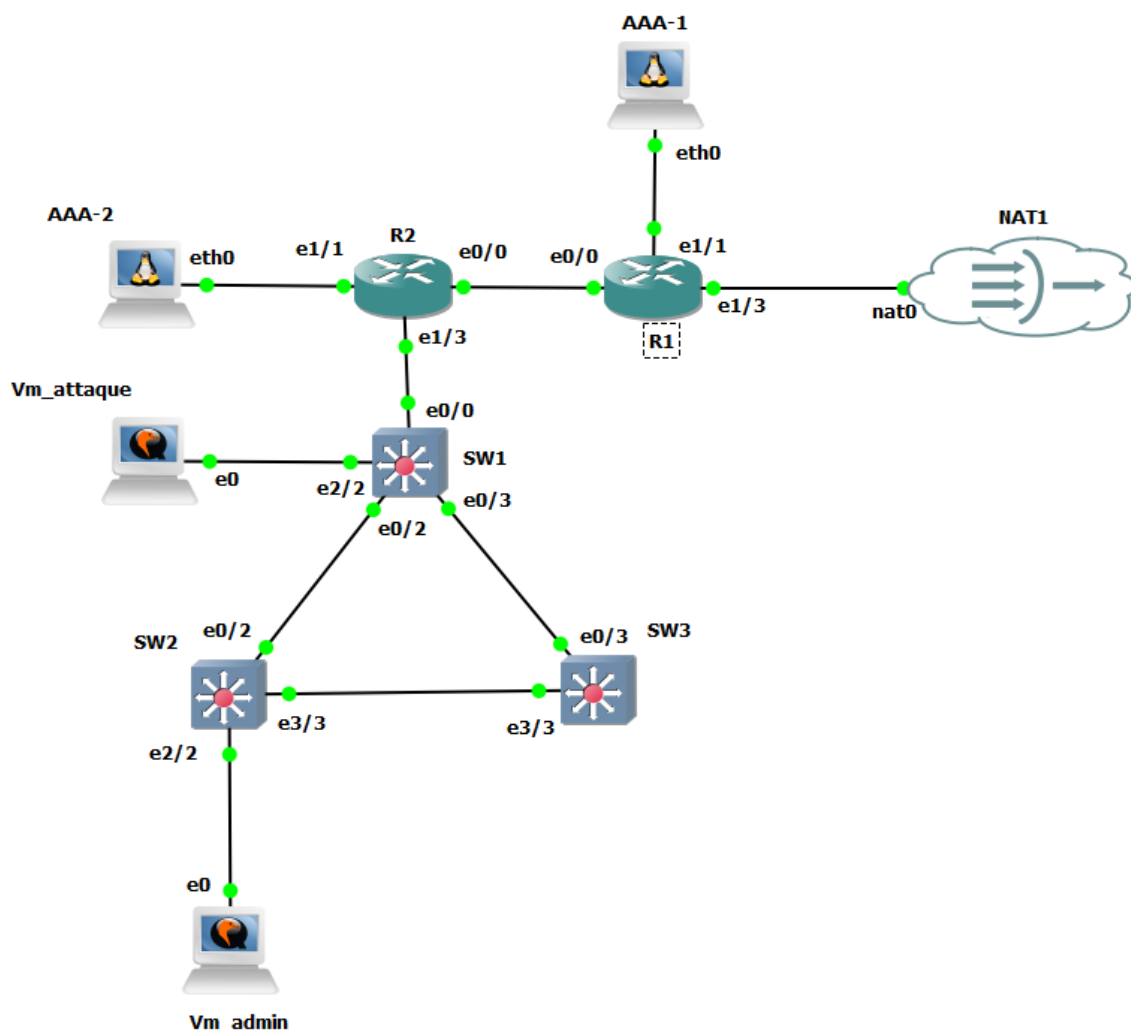
I - Préambule : Le Contexte et les Enjeux

Dans la gestion d'une infrastructure réseau d'entreprise, la sécurisation des équipements de commutation et de routage est la première ligne de défense. Historiquement, l'administration se faisait via des protocoles en clair (Telnet) avec des mots de passe locaux partagés par toute l'équipe informatique.

Cette manipulation a pour objectif de vous faire vivre une attaque réseau classique exploitant ces faiblesses (usurpation d'identité, destruction de configuration sans traçabilité), puis de vous faire déployer l'architecture de remédiation : le standard AAA (Authentication, Authorization, Accounting).

Pour assurer un niveau de sécurité "Entreprise", l'authentification sera déportée sur un serveur RADIUS. Afin d'éviter qu'une panne matérielle ne verrouille l'accès aux équipements, vous implémenterez une politique de haute disponibilité en déployant un serveur RADIUS secondaire et des mécanismes de repli.

Schéma :



Matériel physique requis par paillasse (P = Numéro de paillasse) :

- 3 Commutateurs (Switchs) de type Cisco Catalyst 2960 (SW1, SW2, SW3).
- 2 Routeurs de type Cisco 2600 (R1, R2).
- 2 PC / Serveurs Linux Debian physiques ou virtualisés sur les postes de la salle (AAA-1 et AAA-2).
- 2 PC Windows/Linux (PC-Admin et PC-Attaquant).
- Câbles console, câbles RJ45 droits et croisés.

I.2 – Prérequis et objectifs de la manipulation

Pour aborder ce travail pratique, il est considéré que vous maîtrisez les concepts fondamentaux des réseaux informatiques : configuration de base des équipements actifs (commutateurs et routeurs Cisco), adressage IP, déploiement d'un protocole de routage dynamique (OSPF) et analyse de trames avec Wireshark.

Ces acquis doivent vous permettre de déployer rapidement l'architecture réseau initiale afin de vous consacrer au véritable objectif de cette séance : l'étude et la mise en place de la sécurité via une architecture AAA.

L'enjeu n'est plus ici d'établir la connectivité, mais d'apprendre à protéger l'accès aux équipements eux-mêmes. Vous allez implémenter un contrôle d'accès strict en centralisant l'authentification, les autorisations et la traçabilité des administrateurs sur un serveur RADIUS, tout en assurant la résilience du réseau grâce à des mécanismes de Haute Disponibilité.

Le montage physique de la topologie et la configuration du routage de la phase de préparation devront donc être réalisés en amont pour vous laisser le temps d'assimiler, de configurer et de tester les mécanismes de cybersécurité qui constituent le cœur de ce TP.

II - Préparation (Configurations à injecter en début de séance) - (4 points)

L'objectif de cette phase est de monter l'infrastructure physique et de configurer le routage de base chez vous.

1. Câblage et Adressage IP Réalisez le câblage physique de votre paillasse selon le plan suivant :

- LAN Campus : Branchez le PC-Admin sur SW2 et le PC-Attaquant sur SW1. Adressage : 192.168.P.0/24 (Passerelle R2 : .254).
- Réseau WAN (Interconnexion) : Reliez R2 (Cœur) à R1 (Passerelle) via un câble croisé sur leurs interfaces. Adressage : 10.P.12.0/30 (R1 : .1, R2 : .2).
- Serveur RADIUS Principal (AAA-1) : Connecté sur un port dédié de R1. Adressage : 172.16.P.0/24 (AAA-1 : .10, R1 : .254).
- Serveur RADIUS Secondaire (AAA-2) : Connecté sur SW1. Adressage : 172.17.P.0/24 (AAA-2 : .10, R2 : .254).

2. Configuration Initiale et Routage (Via câble Console)

1. À l'aide du câble console et de l'outil PuTTY/TeraTerm (voir Annexe C), effacez les anciennes configurations des routeurs et switches (write erase puis delete vlan.dat sur les switchs, suivi d'un reload).
2. Configurez les adresses IP sur toutes les interfaces des routeurs.
3. Configurez le protocole OSPF (Area 0) sur R1 et R2 pour propager toutes les routes.

3. La Faille Initiale (Mise en place du piège) Sur les routeurs R1 et R2, nous allons volontairement configurer un accès distant obsolète pour illustrer la mauvaise pratique. Tapez ces commandes :

```
R2(config)# line vty 0 4
```

```
R2(config-line)# password cisco
```

```
R2(config-line)# login
```

Questions de préparation :

1. Fournissez le tableau d'adressage IP complet de votre paillasse.
2. Écrivez les commandes OSPF que vous avez injectées sur R1 et R2.
3. Effectuez un PING depuis le PC-Admin vers le serveur AAA-1. Ce test est-il un succès ? Justifiez la logique de ce test de bout en bout.

ATTENTION : Ne passez pas à la suite tant que le PING entre le PC-Admin et les deux serveurs Linux (AAA-1 et AAA-2) ne fonctionnent pas.

III - Manipulation (vérification du fonctionnement durant la séance) : (16 points)

L'objectif de cette partie consiste à mettre en évidence les failles critiques d'une gestion réseau basique, puis à configurer les équipements de la topologie afin de sécuriser le plan d'administration via une architecture AAA complète et redondante.

Dans votre compte-rendu, vous devrez renseigner toutes les commandes en les adaptant à votre paillasse.

L'entreprise Riviera-Tech est en crise. Un attaquant inconnu a réussi à s'infiltrer et à modifier la configuration du cœur de réseau. Vous avez été appelé en urgence en tant qu'expert en cyber-défense. Votre première mission : comprendre comment le pirate est entré.

III.1 - Phase 1 : L'Interception et la vulnérabilité des flux en clair (30 minutes : 3 pts)

A ce stade, vous avez configuré un accès distant basique sur vos routeurs en utilisant le protocole Telnet et un mot de passe local partagé (cisco). Ce protocole historique ne chiffre pas les données encapsulées. N'importe quel individu ayant accès au domaine de diffusion (ou utilisant des techniques de port mirroring/ARP spoofing) peut intercepter ce trafic.

L'attaquant est probablement encore à l'écoute sur le réseau. Vous allez utiliser ses propres méthodes pour inspecter le trafic et prouver à la direction que la configuration actuelle est une passoire.

Manipulation 1 : Capture de trames et exploitation de la faille Telnet

Afin de visualiser cette vulnérabilité, vous allez utiliser un analyseur de protocole.

1. Sur le commutateur d'accès SW1, configurez une session Port Mirroring en utilisant vos acquis des modules précédents. Le port source à écouter est celui qui mène au routeur R2, et le port de destination doit être celui sur lequel est branché le PC-Attaquant.
2. Lancez une capture réseau avec Wireshark sur le lien physique reliant SW1 à R2.
3. Depuis le PC-Admin, initiez une session Telnet vers le routeur de cœur de réseau (R2) via la commande telnet 192.168.P.254. Saisissez le mot de passe cisco.
4. Stoppez la capture Wireshark. Filtrez le trafic avec le mot-clé telnet, faites un clic droit sur un paquet d'échange et sélectionnez Follow TCP Stream.

Questions : analyse de la faille et de l'anonymat

- Identifiez et montrez à l'enseignant les informations critiques récupérées en clair dans Wireshark.
- L'interface WAN étant désactivée, l'entreprise lance un audit. Le routeur R2 possède-t-il dans ses logs le nom de la personne physique (admin, tech ou l'attaquant) qui a commis cette action destructrice ? Justifiez l'impact de l'utilisation d'un mot de passe unique partagé.

APPELEZ L'ENSEIGNANT AFIN DE VERIFIER VOS MANIPULATIONS !!!

III.2 - Phase 2 : Le 1er "A" (Authentication) via RADIUS et SSH (45 minutes : 5 pts)

L'hémorragie est confirmée. Il faut maintenant barricader le système. Vous allez remplacer cette vieille serrure rouillée (Telnet) par un sas de sécurité ultra-moderne contrôlé par un serveur d'identité strict (RADIUS).

Il est donc nécessaire d'interdire le trafic Telnet et de forcer l'utilisation de SSH pour chiffrer les échanges. De plus, pour supprimer l'anonymat constaté à la manipulation précédente, nous allons déporter la vérification des identités sur un serveur externe grâce au protocole RADIUS. Ainsi, chaque administrateur possèdera son propre compte.

Manipulation 2 : Configuration de l'authentification centralisée sur R2

Après avoir réactivé l'interface WAN sur R2 via le port console, vous devez générer des clés de chiffrement pour le SSH, puis déclarer le serveur RADIUS Principal (AAA-1) pour gérer l'authentification.

```
R2(config)# aaa new-model
```

```
R2(config)# radius-server host [IP_SRV_RADIUS1] auth-port 1812
```

```
R2(config)# radius-server host [IP_SRV_RADIUS1] acct-port 1813
```

```
R2(config)# radius-server host [IP_SRV_RADIUS1] key gns3
```

```
R2(config)# aaa authentication login SSH_AUTH group radius local
```

```
R2(config)# radius-server timeout 3
```

```
R2(config)# radius-server retransmit 2
```

Activer SSH sur R2 à l'aide des connaissances acquises en 1^{ère} année sans oublier :

```
R2(config-line)# login authentication SSH_AUTH
```

Modifier le fichier : /etc/freeradius/3.0/users

```
admin Cleartext-Password := "rt2026"  
    Service-Type = Login-User,  
    Cisco-AVPair = "shell:priv-lvl=15"  
tech Cleartext-Password := "rt2026"  
    Service-Type = Login-User,  
    Cisco-AVPair = "shell:priv-lvl=1"
```

Modifier le fichier : /etc/freeradius/3.0/clients.conf

```
client 172.16.10.0/24 {  
    secret = gns3  
    shortname = lab-rt  
}  
service freeradius restart
```

Pour tester la connexion SSH au routeur :

```
ssh -o KexAlgorithms=+diffie-hellman-group1-sha1 -o HostKeyAlgorithms=+ssh-rsa -o  
Ciphers=+aes128-cbc tech@192.168.10.254
```

La commande `aaa new-model` est cruciale car elle active l'architecture AAA sur l'IOS Cisco, ce qui débloque les commandes spécifiques. La directive `aaa authentication...` permet de spécifier la base de données qui sera interrogée lorsqu'un utilisateur tentera de se connecter. Ici, le routeur interrogera d'abord les serveurs RADIUS connus.

Questions : évolution des tests de connectivité et vérification

- Depuis le PC-Admin, connectez-vous avec un client SSH en utilisant le compte RADIUS admin et le mot de passe rt2026. Observez la capture Wireshark en parallèle. Le mot de passe est-il toujours lisible ?
- Expliquez le rôle exact du mot-clé local situé à la toute fin de la commande `aaa authentication login SSH_AUTH group radius local`. Que se passe-t-il si le serveur RADIUS répond formellement "Mot de passe incorrect" ?
- Quelle commande avez-vous utilisée pour vous assurer que Telnet est définitivement désactivé sur les lignes virtuelles, forçant ainsi l'usage exclusif de SSH ?

APPELEZ L'ENSEIGNANT AFIN DE VERIFIER VOS MANIPULATIONS !!!

III.3 - Phase 3 : Les 2ème et 3ème "A" (Authorization & Accounting) (45 minutes : 4 pts)

Le réseau est verrouillé de l'extérieur, mais que se passe-t-il si la menace vient de l'intérieur ? Vous décidez de brider les accès du technicien junior (tech) et de mettre sous surveillance constante toutes les actions de l'administrateur en chef (admin).

Savoir qui entre sur l'équipement est une bonne chose, mais c'est insuffisant. Il faut contrôler ce que l'utilisateur a le droit de faire une fois connecté (Autorisation) et garder une trace indélébile de l'intégralité de ses actions (Accounting).

Manipulation 3 : Mise en place des autorisations et de la traçabilité sur R2

Le serveur RADIUS AAA-1 est déjà configuré pour renvoyer un niveau de privilège 1 pour l'utilisateur tech et un niveau 15 pour admin. Il faut indiquer à R2 d'appliquer ces droits, et d'envoyer un rapport au serveur RADIUS chaque fois qu'une commande est tapée.

Authorization :

```
R2(config)# aaa authorization exec default group radius local
R2(config)# aaa authentication enable default group radius enable
```

Accounting :

```
R2(config)# aaa accounting exec default start-stop group radius
R2(config)# aaa accounting commands 15 default start-stop group radius
```

```
service freeradius stop
freeradius -X
```

Questions : vérification de la granularité des droits et des logs

- Connectez-vous à R2 en SSH avec le compte tech. Essayez de passer en mode privilégié (enable ou configure terminal). Que se passe-t-il et pourquoi ?
- Connectez-vous en SSH avec le compte admin. Tapez la commande `sh ip route` et fermez la session.
- Ouvrez la console du serveur Linux **AAA-1**. Affichez le fichier de log RADIUS (généralement situé dans `/var/log/freeradius/radacct/`). Retrouvez-vous la trace horodatée de la connexion et de la commande de l'admin ? Montrez-la à l'enseignant.

APPELEZ L'ENSEIGNANT AFIN DE VERIFIER VOS MANIPULATIONS !!!

III.4 - Phase 4 : Haute Disponibilité et Résilience (SPOF) (45 minutes : 4 pts)

Furieux de ne plus avoir accès au système, le pirate riposte en détruisant physiquement le lien WAN vers le datacenter principal. Si vous n'avez pas de plan de secours, plus personne ne pourra s'authentifier et Riviera Tech sera totalement paralysée.

L'authentification est désormais robuste. Cependant, nous n'avons pas de solution disponible en cas de panne du système. Si le lien WAN entre R1 et R2 est rompu, le routeur R2 ne pourra plus joindre le serveur AAA-1 situé dans le Datacenter. Les administrateurs locaux du Campus seront alors enfermés en dehors de leurs propres équipements.

Manipulation 4 : Configuration de la redondance RADIUS

Pour pallier ce problème, un serveur RADIUS secondaire (AAA-2) a été placé sur un réseau du routeur R2. Il convient de définir un groupe de serveurs RADIUS sur R2, incluant le serveur principal et le serveur de secours local, ainsi qu'un compte en cas de coupure totale.

Modifier le fichier : /etc/freeradius/3.0/users

```
admin Cleartext-Password := "rt2026"
```

```
Service-Type = Login-User,
```

```
Cisco-AVPair = "shell:priv-lvl=15"
```

```
tech Cleartext-Password := "rt2026"
```

```
Service-Type = Login-User,
```

```
Cisco-AVPair = "shell:priv-lvl=1"
```

Modifier le fichier : /etc/freeradius/3.0/clients.conf

```
client 172.17.10.0/24 {
```

```
secret = gns3
```

```
shortname = lab-rt
```

```
}
```

```
service freeradius restart
```

```
R2(config)# radius-server host [IP_SRV_RADIUS2]
```

```
R2(config)# radius-server host [IP_SRV_RADIUS2] auth-port 1812
```

```
R2(config)# radius-server host [IP_SRV_RADIUS2] acct-port 1813
```

```
R2(config)# radius-server host [IP_SRV_RADIUS2] key gns3
```

Grâce à cette configuration, le routeur interrogera les serveurs du groupe dans l'ordre d'apparition. Si le premier ne répond pas grace au timeout, il passera au second.

Création d'un compte de secours sur R2 :

```
R2(config)# username secours privilege 15 secret ausecoursrt06
```

Questions : test de la résilience

- Simulez la coupure WAN : débranchez physiquement le câble reliant R1 à R2.
- Depuis le PC-Admin, connectez-vous à R2 en SSH. La connexion est-elle un succès ?
- Avez-vous constaté un léger temps de latence avant l'apparition de l'authentification ? A quoi est-il dû ?
- L'authentification s'est-elle faite sur AAA-1, AAA-2, ou sur la base locale de R2 ? Justifiez.

APPELEZ L'ENSEIGNANT AFIN DE VERIFIER VOS MANIPULATIONS !!!

IV - Désinstallation (Obligatoire 10 min avant la fin)

L'objectif est de remettre les baies de brassage et les équipements dans un état neutre.

1. Sur R1, R2, SW1, SW2 et SW3 : tapez write erase (confirmez), puis delete vlan.dat (sur les switches). Tapez reload et ne sauvegardez pas la configuration courante.
2. Décâblez proprement.
3. Éteignez les VM.
4. Faites vérifier votre paillasse par l'enseignant. **(-2 points si non respecté)**

ANNEXES : Installation, Outils et Manuels

ANNEXE A : Installation et Utilisation de Wireshark

Rôle : Analyseur de paquets (Sniffer) utilisé pour l'audit et le piratage réseau passif.

1. Installation (Windows) : Téléchargez l'exécutable sur <https://www.wireshark.org/>. Lors de l'installation, assurez-vous de cocher l'installation de Npcap (le pilote de capture réseau).
2. Installation (Linux Debian) : Dans un terminal, tapez `sudo apt update && sudo apt install wireshark`. Répondez "Oui" à la question permettant aux non-root de capturer des paquets.
3. Utilisation dans le TP : * Lancez le logiciel. Double-cliquez sur l'interface réseau active (ex: Ethernet0 ou eth0).
 - Dans la barre de filtre en haut, tapez `telnet` ou `ssh` pour isoler les flux.
 - Clic droit sur une ligne de flux `Follow TCP Stream` pour reconstituer la conversation entre le client et le routeur.

ANNEXE B : Installation et Configuration du Serveur FreeRADIUS (Linux Debian)

Rôle : Déployer le serveur AAA physique (AAA-1 et AAA-2).

1. Installation : Sur la machine Linux, ouvrez un terminal administrateur et exécutez : `sudo apt update` puis `sudo apt install freeradius freeradius-utils`.
2. Déclaration du Routeur R2 (Client) : Éditez le fichier `/etc/freeradius/3.0/clients.conf` (via `nano` ou `vim`) et ajoutez à la fin :

```
client routeur_r2 {
```

```
    ipaddr = 10.P.12.2 # (ou l'IP source de R2)
```

```
    secret = gns3
```

```
}
```

3. Création des utilisateurs (admin et tech) : Éditez le fichier `/etc/freeradius/3.0/users` et ajoutez tout en haut :

```
admin Cleartext-Password := "rt2026"
```

```
Cisco-AVPair = "shell:priv-lvl=15"
```

tech Cleartext-Password := "rt2026"

Cisco-AVPair = "shell:priv-lvl=1"

(La variable Cisco-AVPair indique au routeur Cisco le niveau de droit attribué lors de l'autorisation).

Démarrage et Test : Redémarrez le service : `sudo systemctl restart freeradius`. Pour tester localement si le serveur fonctionne avant de le brancher au routeur, utilisez l'utilitaire `radtest` : `radtest admin rt2026 localhost 0 testing123`. Un message Access-Accept confirmera le bon fonctionnement.

ANNEXE C : Utilisation d'un Émulateur de Terminal (PuTTY)

Rôle : Configurer les équipements réseau physiques via le port Console série.

1. Installation : Sous Windows, téléchargez PuTTY (`putty.exe`). Il ne nécessite aucune installation.
2. Branchement physique : Connectez le câble bleu ciel "Rollover" entre le port COM/USB du PC et le port "Console" (RJ45) à l'arrière du routeur Cisco.
3. Configuration : * Dans PuTTY, cochez la case "Serial".
 - Dans "Serial line", indiquez le port (ex: COM3 sous Windows, vérifiable dans le Gestionnaire de périphériques, ou `/dev/ttyUSB0` sous Linux).
 - "Speed" : 9600 bauds. Cliquez sur "Open". Appuyez sur la touche "Entrée" pour faire apparaître le prompt du routeur (Router>).